

On the Security and Privacy Risks of Browser Extensions

Dr.-Ing. Aurore Fass

Tenured Researcher — Inria Centre at Université Côte d'Azur (since Dec 1, 2025)

Dr.-Ing. Aurore (/ʊRʊR/) FASS

 2017: Graduated from [TELECOM Nancy](#), a French “Grande École” (FR)

 2017–21: PhD Student + Postdoc at [CISPA / Saarland University](#) (DE)

 2021–23: Visiting Assistant Professor at [Stanford University](#) (US)

 2023–25: Tenure-Track Faculty W2 at [CISPA](#) (DE)

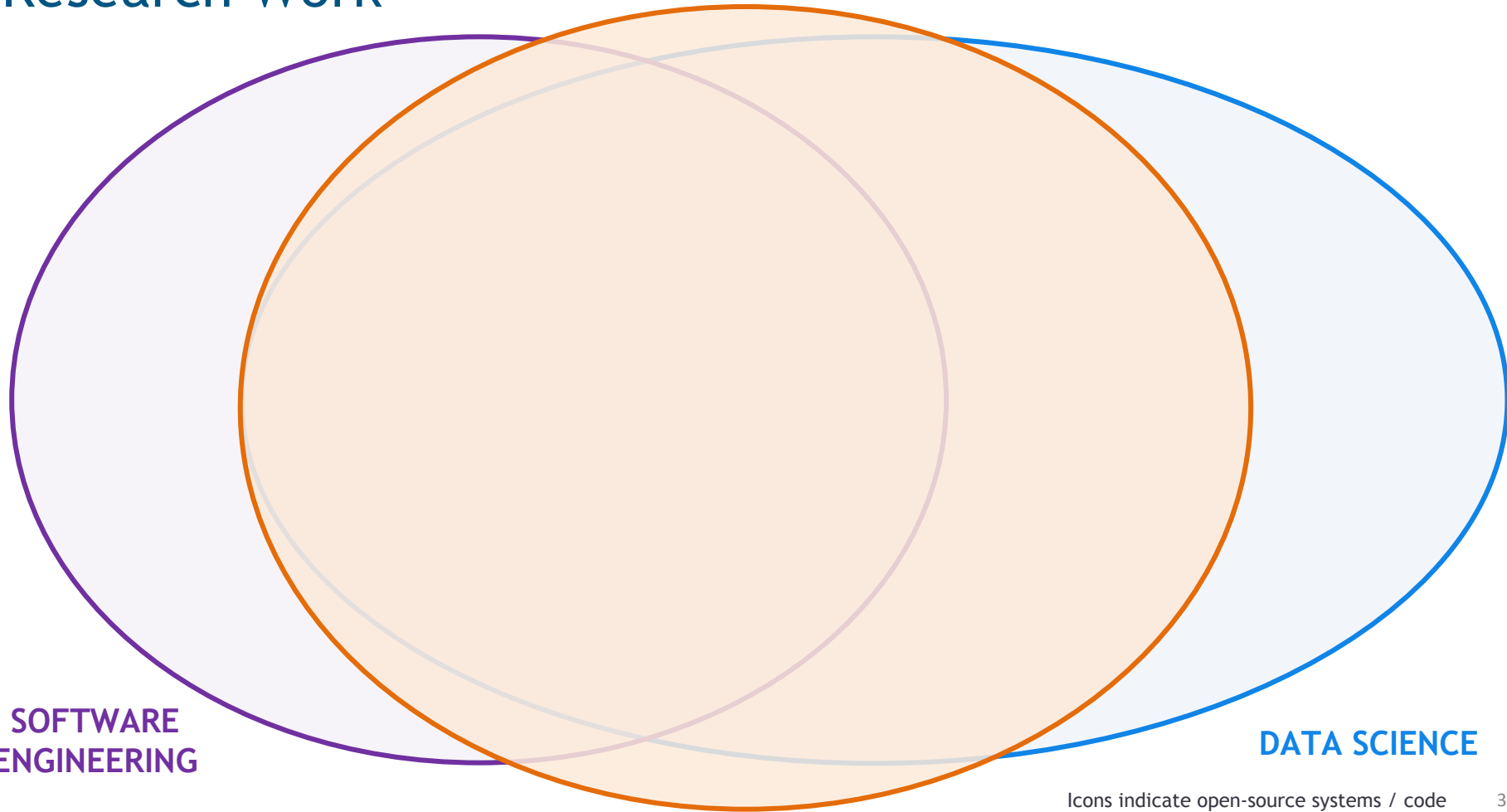
 2025–: Tenured Researcher at [Inria Centre at Université Côte d’Azur](#) (FR)

Research Work

WEB SECURITY & PRIVACY

SOFTWARE
ENGINEERING

DATA SCIENCE



Malicious
JavaScript



Moog et al.
DSN 2021

Fass et al.
DIMVA
2018



Fass et al.
CCS 2019

Fass et al.
ACSAC
2019

Malicious
JavaScript

Browser
Extensions



Moog et al.
DSN 2021



Agarwal et al.
CCS 2024



Chaudhry et al.
MADWeb 2026



Rosenzweig
et al. TWEB
2026

Fass et al.
DIMVA
2018



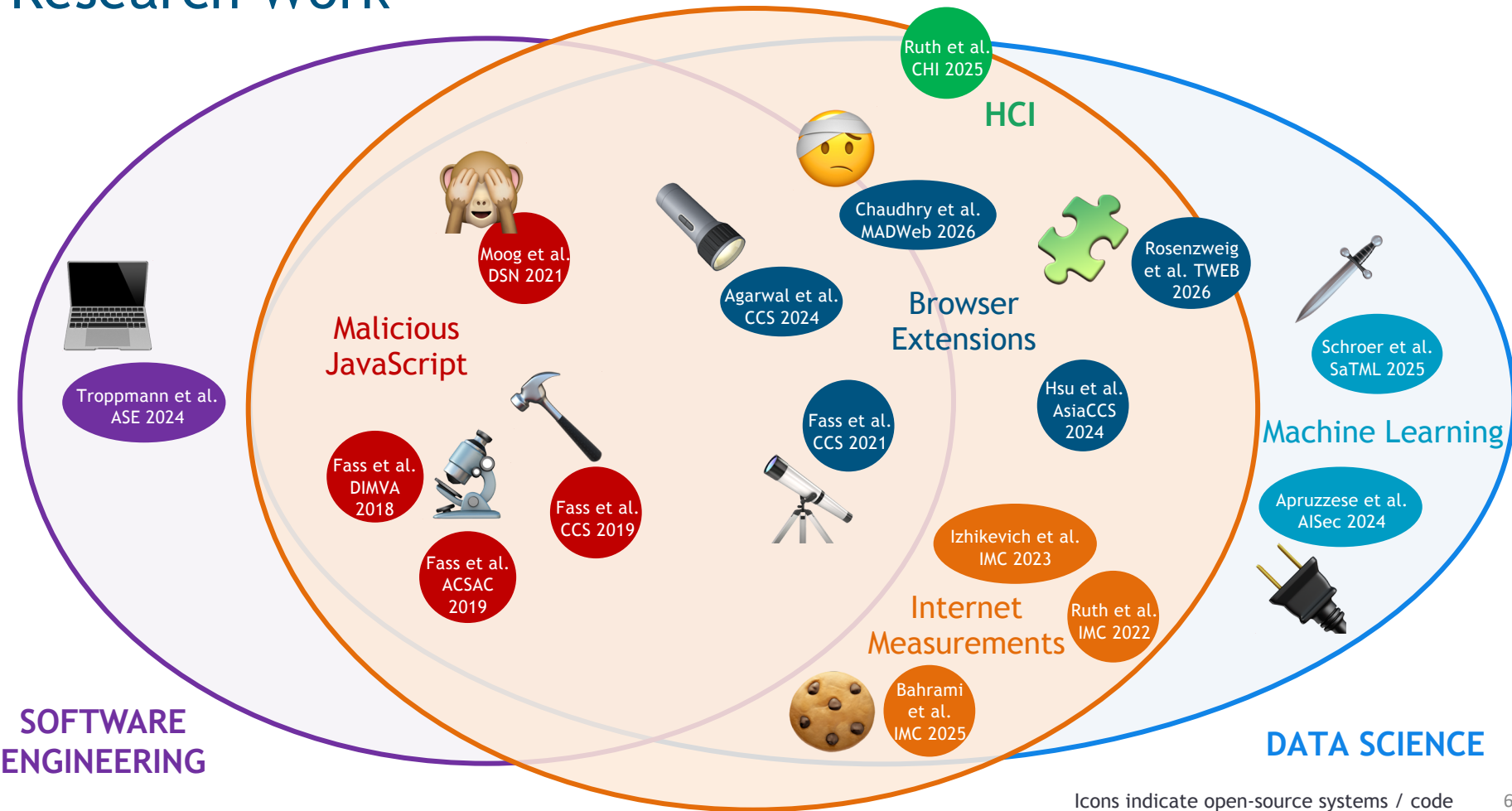
Fass et al.
CCS 2019

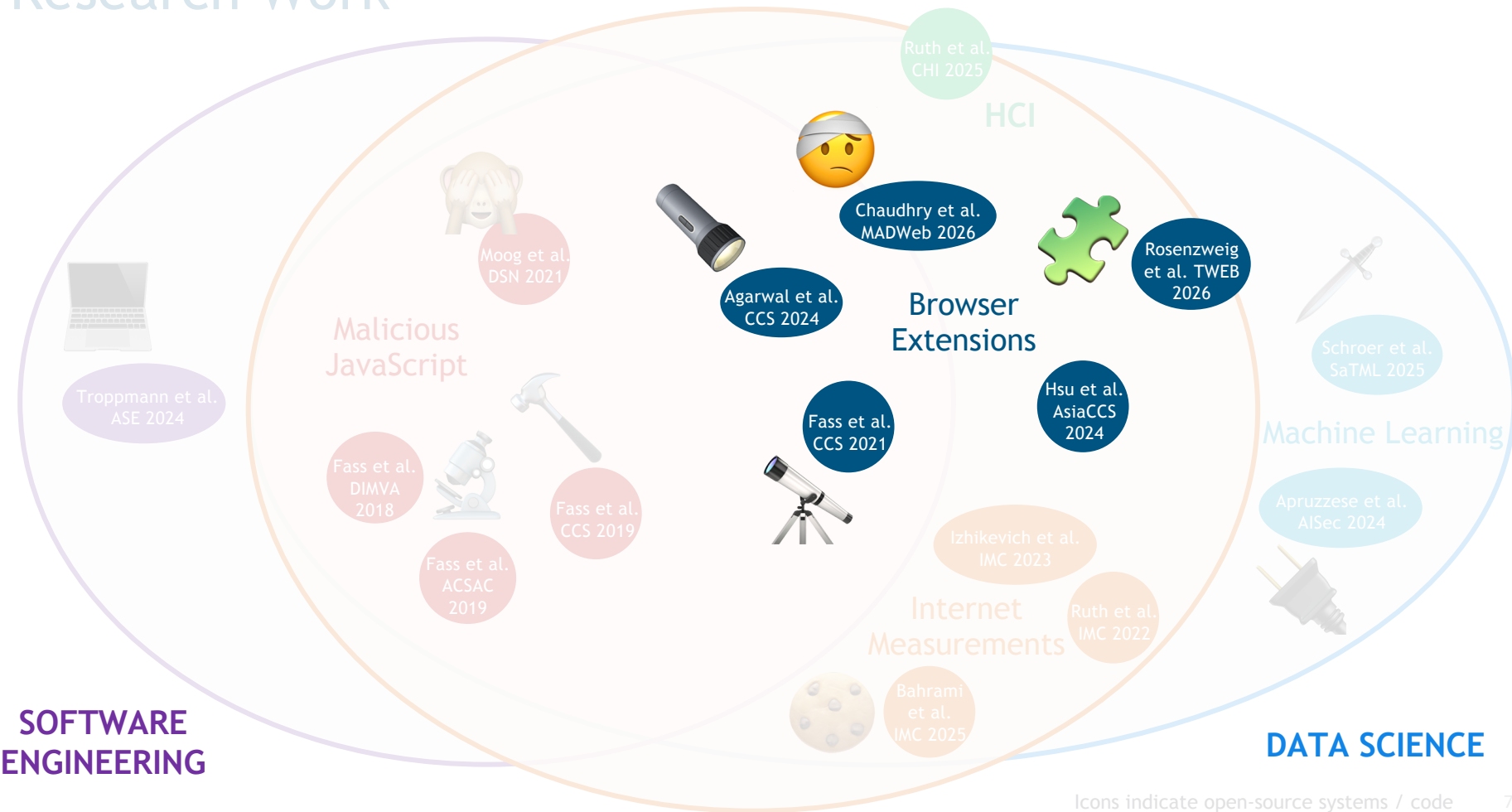
Fass et al.
ACSAC
2019

Fass et al.
CCS 2021



Hsu et al.
AsiaCCS
2024





What are Browser Extensions?

- Third-party programs to **improve user browsing experience**



Adblock Plus - free ad blocker

Offered by: adblockplus.org



Skype

Offered by: www.skype.com



Adobe Acrobat

Offered by: Adobe Inc.



Grammarly for Chrome

Offered by: grammarly.com



Honey

Offered by: <https://www.joinhoney.com>



Google Translate

Offered by: translate.google.com



LastPass: Free Password Manager

Offered by: LastPass



Cisco Webex Extension

Offered by: webex.com

- ~270k Chrome extensions** totaling **~3B active users**

➤ Necessitates a thorough **security and privacy assessment**

How Secure are Browser Extensions?

- Browser extensions provide **additional functionality**...
- ... so browser extensions need **additional & elevated privileges** compared to web pages
 - e.g., ad-blockers need to modify web page content or intercept network requests
 - e.g., extensions can download arbitrary files and access cross-domain data; while web pages cannot (blocked by the Same-Origin Policy)
- **Browser extensions are an attractive target for attackers** 😈

Dangerous Browser Extensions

→ Extensions can put their users' security & privacy at risk:

- **Contain malware:** designed by malicious actors to harm victims
 - E.g., propagate malware, steal users' credentials, track users [1, 3]
- **Contain vulnerabilities:** designed by well-intentioned developers... but buggy
 - E.g., can lead to user-sensitive data exfiltration [1, 2]
- **Violate the Chrome Web Store policies**
 - E.g., deceive users, promote unlawful activities, lack a privacy policy [1]
- **Be fingerprintable:** can be recognized and uniquely identified
 - E.g., can lead to user tracking or inferring of user personal information [4]

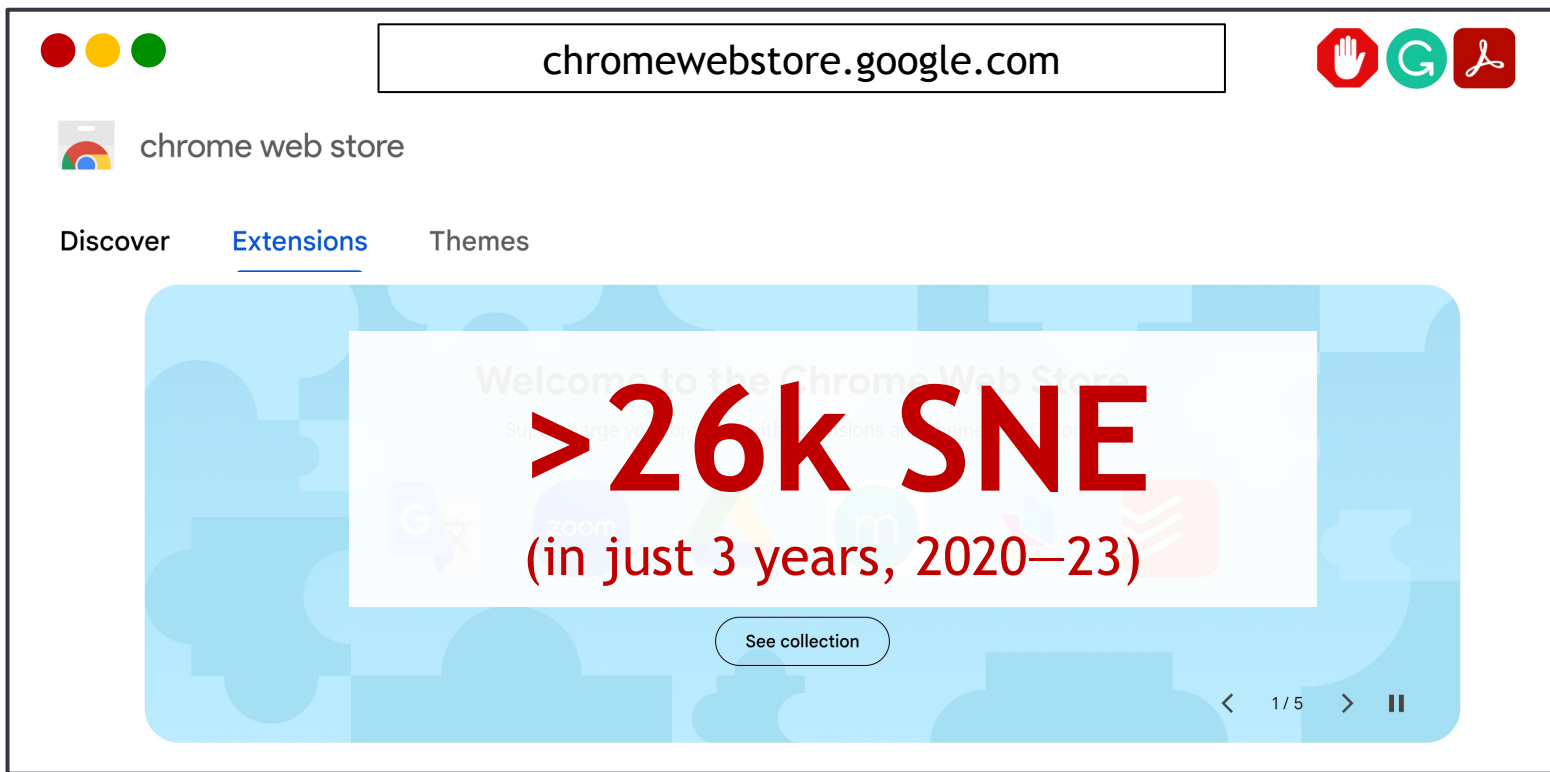
Dangerous Browser Extensions

→ Extensions can put their users' security & privacy at risk:

- **Contain malware:** designed by malicious actors to harm victims
 - E.g., propagate malware, steal users' credentials, track users [1, 3]
- **Contain vulnerabilities:** designed by well-intentioned developers... but buggy
 - E.g., can lead to user-sensitive data exfiltration [1, 2]
- **Violate the Chrome Web Store policies**
 - E.g., deceive users, promote unlawful activities, lack a privacy policy [1]
- **Be fingerprintable:** can be recognized and uniquely identified
 - E.g., can lead to user tracking or inferring of user personal information [4]

➤ **Security-Noteworthy Extensions (SNE) [1]**

How many Security-Noteworthy Extensions (SNE) are there?



Main Findings on the Chrome Web Store

- **350M users** installed **Security-Noteworthy Extensions** in 2020–2023
- These **dangerous extensions** stay in the Chrome Web Store *for years*
- **60%** of extensions have **never received a single update**

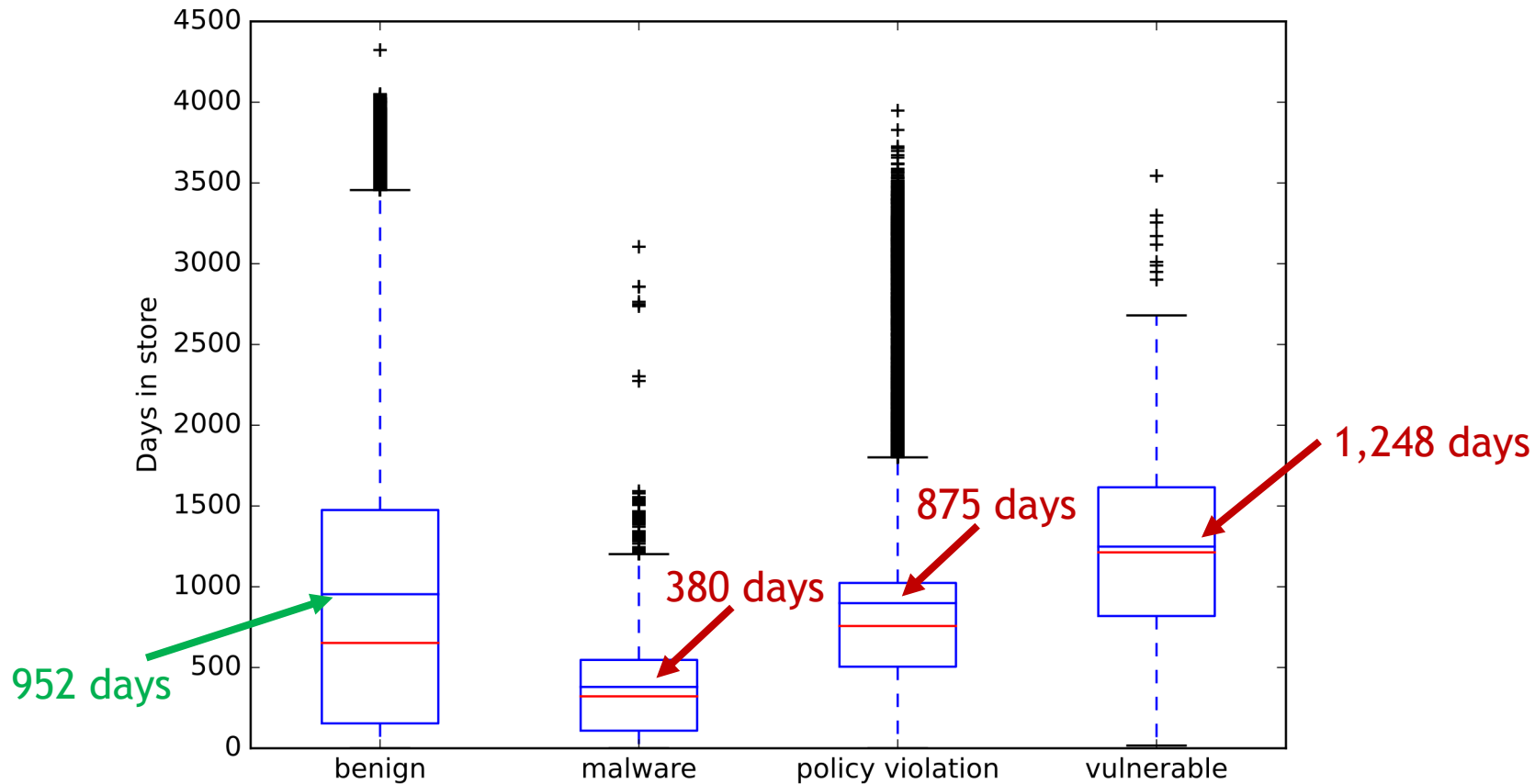


> What is in the Chrome Web Store?

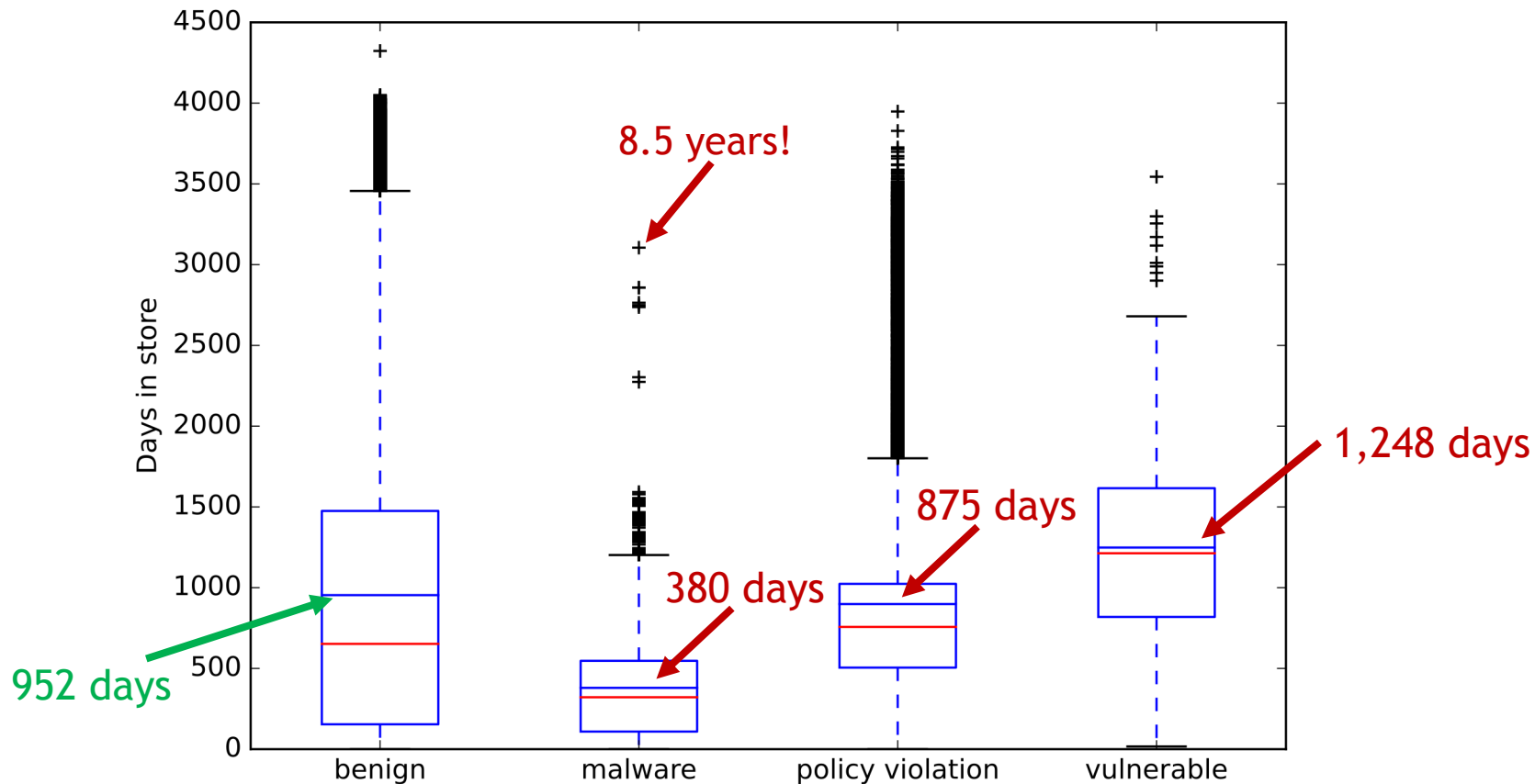
In *ACM AsiaCCS 2024*. Sheryl Hsu, Manda Tran, and Aurore Fass



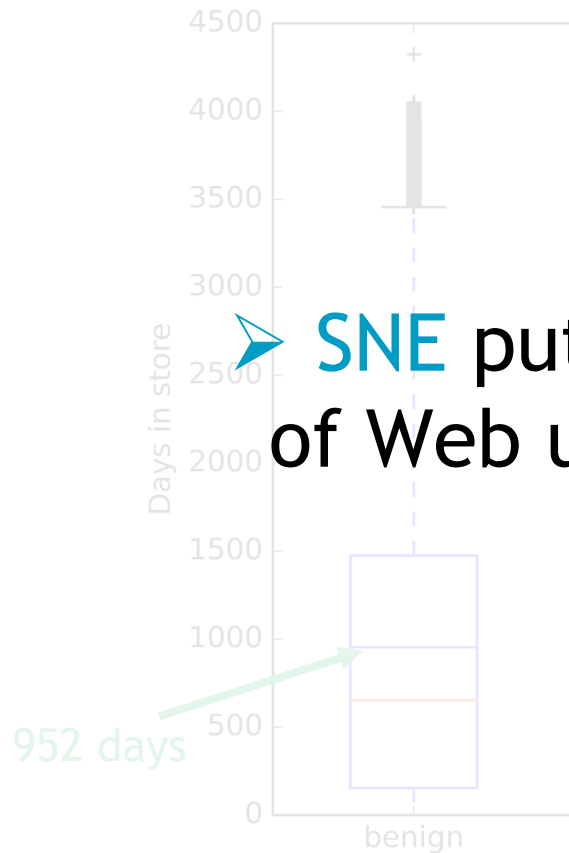
Number of Days in the CWS



Number of Days in the CWS



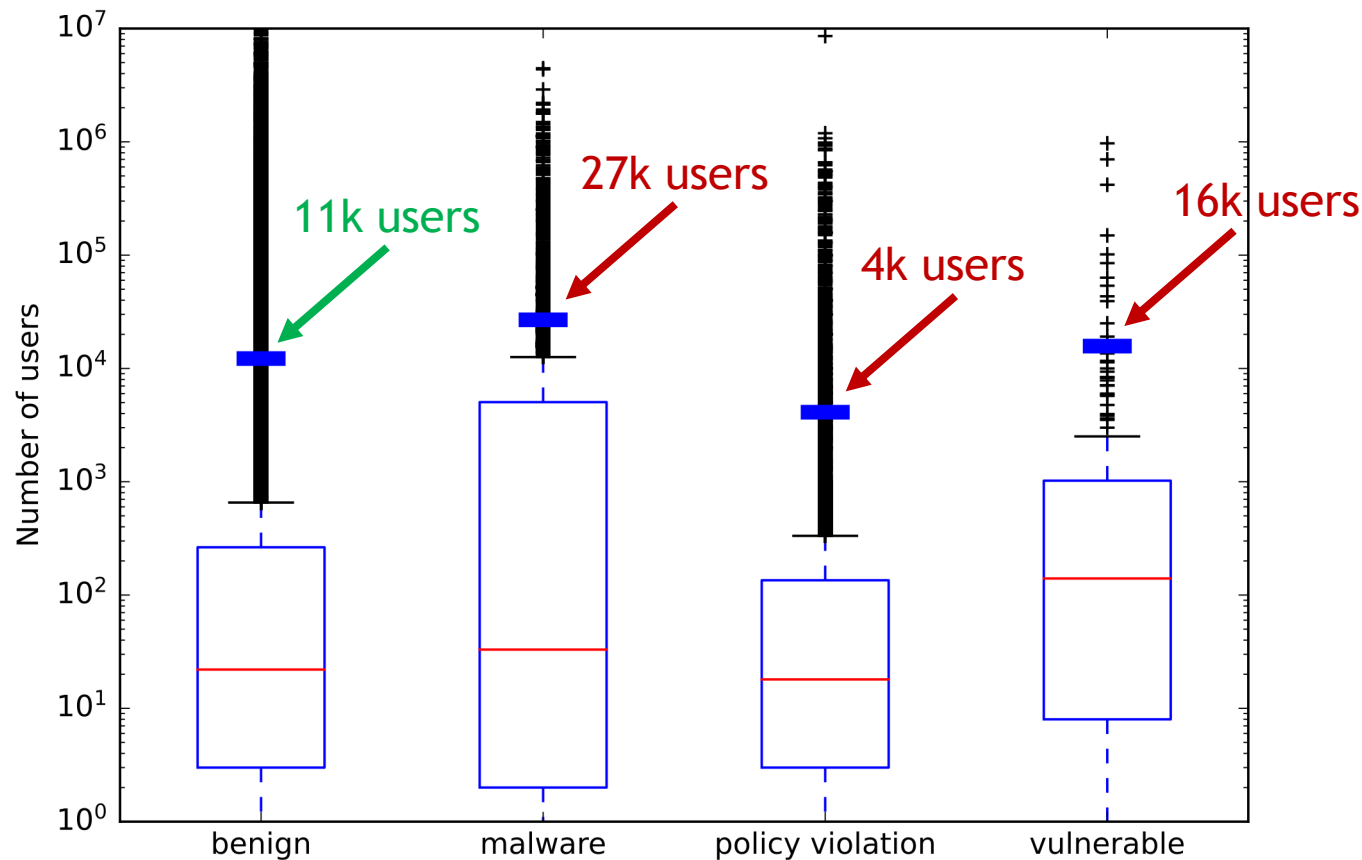
Number of Days in the CWS



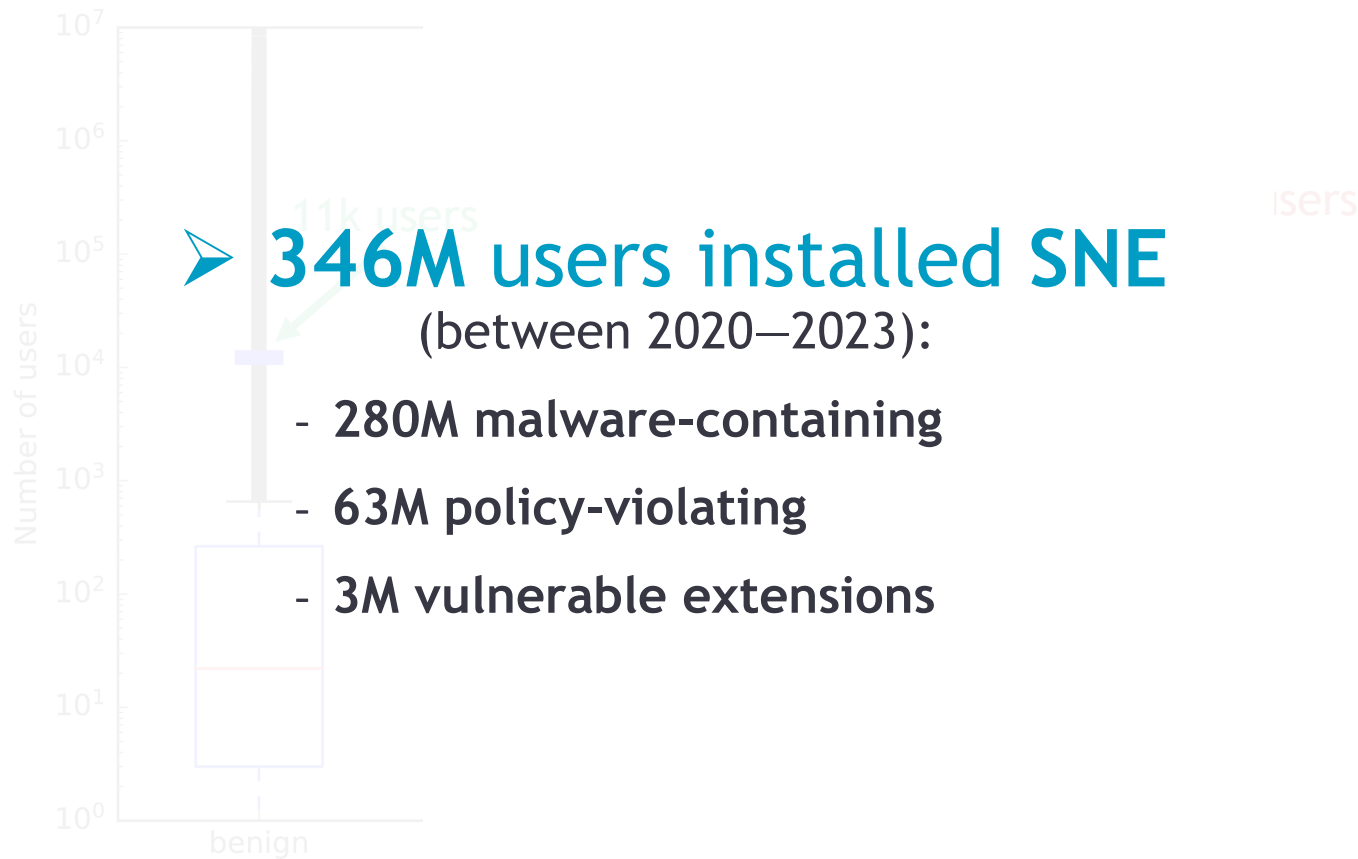
➤ SNE put the security & privacy of Web users *at risk for years*

,248 days

Number of Users



Number of Users



Detecting Vulnerable Extensions

Analysis of Vulnerable Extensions: Threat Model

Challenging to detect due to their inherently benign intent (*benign-but-buggy*)



Analysis of Vulnerable Extensions: Threat Model

Challenging to detect due to their inherently benign intent (*benign-but-buggy*)



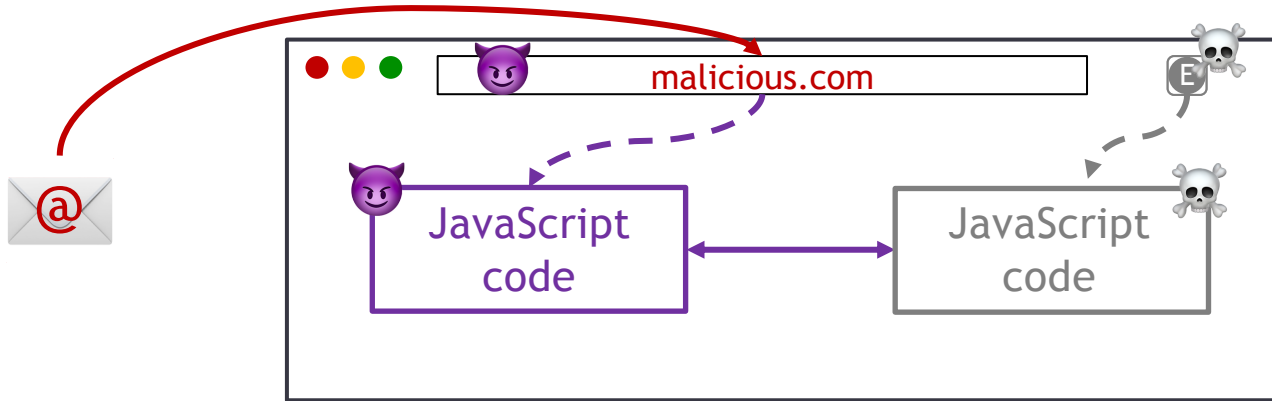
Analysis of Vulnerable Extensions: Threat Model

Challenging to detect due to their inherently benign intent (*benign-but-buggy*)



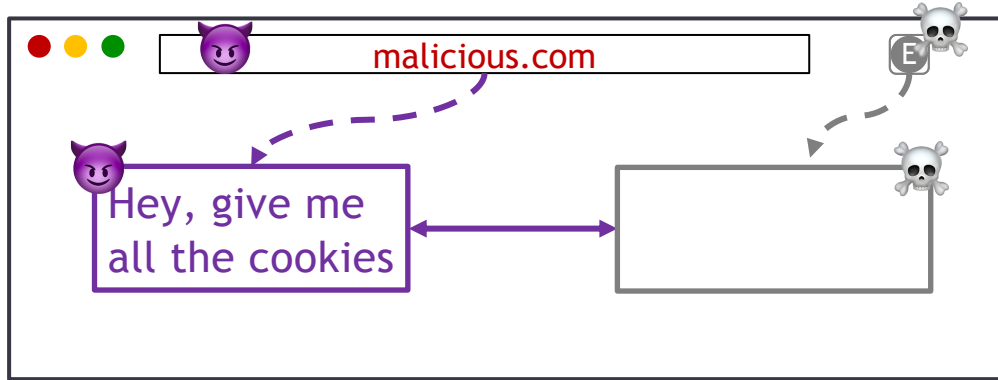
Analysis of Vulnerable Extensions: Threat Model

Challenging to detect due to their inherently benign intent (*benign-but-buggy*)



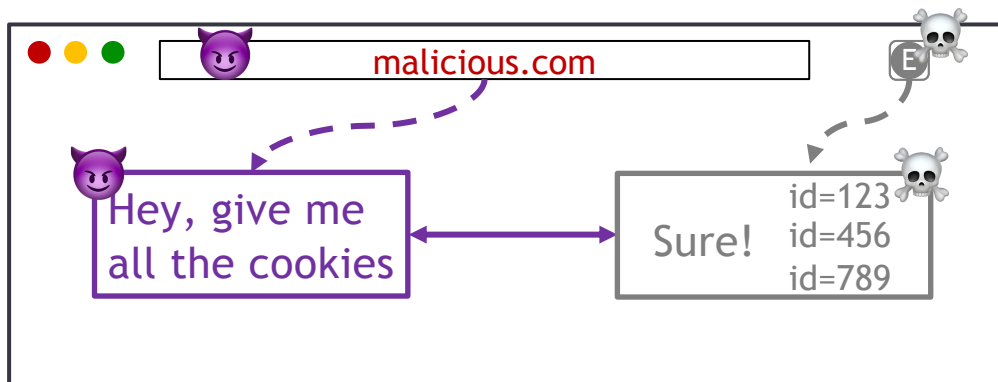
Analysis of Vulnerable Extensions: Threat Model

Challenging to detect due to their inherently benign intent (*benign-but-buggy*)



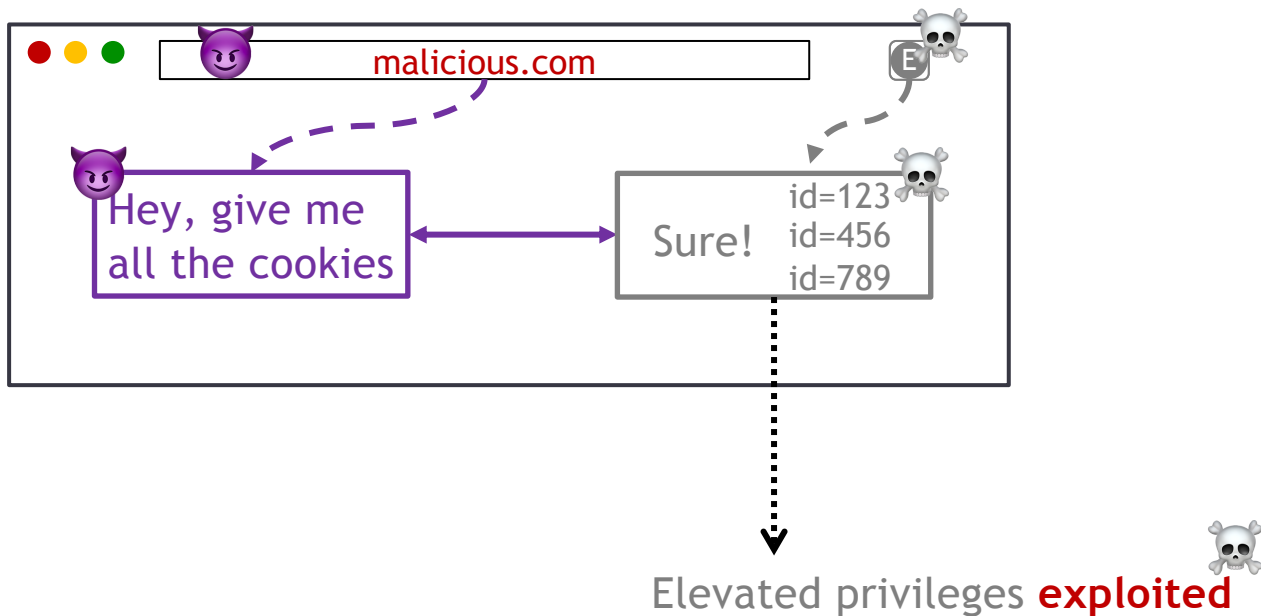
Analysis of Vulnerable Extensions: Threat Model

Challenging to detect due to their inherently benign intent (*benign-but-buggy*)



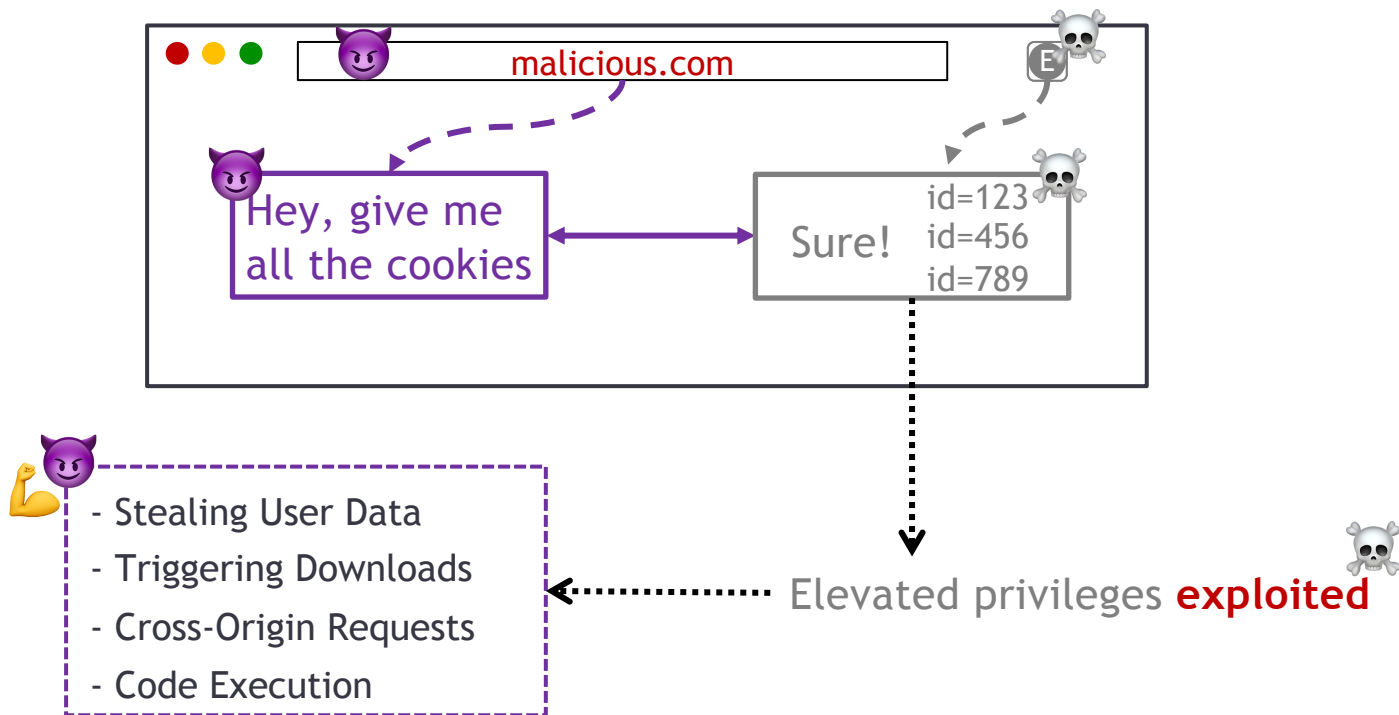
Analysis of Vulnerable Extensions: Threat Model

Challenging to detect due to their inherently benign intent (*benign-but-buggy*)



Analysis of Vulnerable Extensions: Threat Model

Challenging to detect due to their inherently benign intent (*benign-but-buggy*)



Detecting Vulnerable Extensions



> DOUBLEX: Statically Detecting Vulnerable Data Flows in Browser Extensions

In ACM CCS 2021. Aurore Fass, Dolière Francis Somé, Michael Backes, and Ben Stock

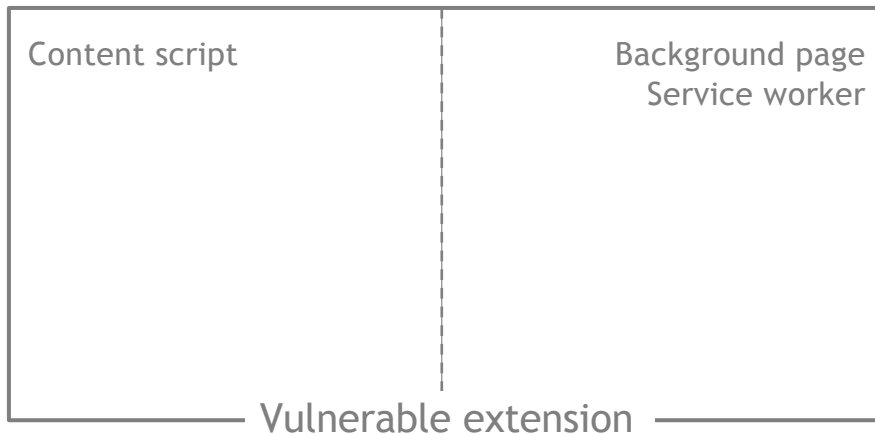


Detecting Vulnerable Extensions



> DOUBLEX: Statically Detecting Vulnerable Data Flows in Browser Extensions

In ACM CCS 2021. Aurore Fass, Dolière Francis Somé, Michael Backes, and Ben Stock



Detecting Vulnerable Extensions



> DOUBLEX: Statically Detecting Vulnerable Data Flows in Browser Extensions

In ACM CCS 2021. Aurore Fass, Dolière Francis Somé, Michael Backes, and Ben Stock



Malicious web page

Content script

Background page
Service worker

Vulnerable extension

Detecting Vulnerable Extensions



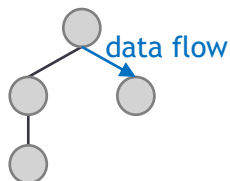
> DOUBLEX: Statically Detecting Vulnerable Data Flows in Browser Extensions

In ACM CCS 2021. Aurore Fass, Dolière Francis Somé, Michael Backes, and Ben Stock

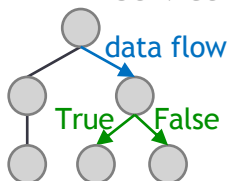


Malicious web page

Content script



Background page
Service worker



Vulnerable extension

Per-component JavaScript code abstraction

- AST (Abstract Syntax Tree)
- Control flow
- Data flow
- Pointer analysis

Detecting Vulnerable Extensions

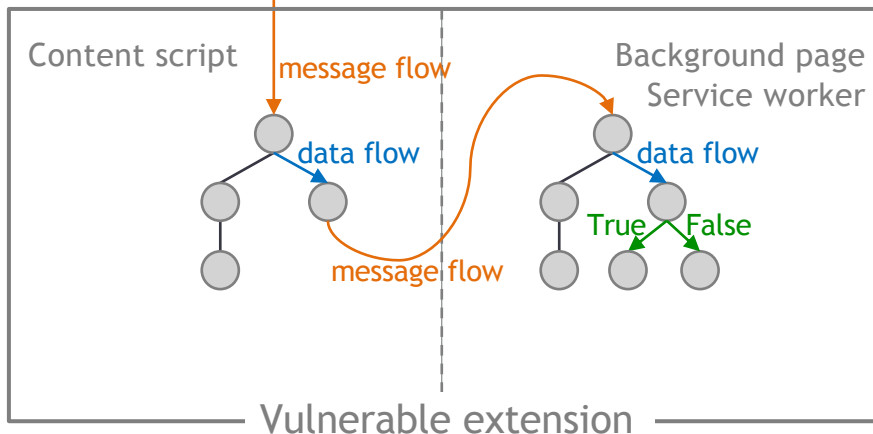


> DOUBLEX: Statically Detecting Vulnerable Data Flows in Browser Extensions

In ACM CCS 2021. Aurore Fass, Dolière Francis Somé, Michael Backes, and Ben Stock



Malicious web page



Per-component JavaScript code abstraction

- AST (Abstract Syntax Tree)
- Control flow
- Data flow
- Pointer analysis

Extension Dependence Graph (EDG)

- Message interactions

Detecting Vulnerable Extensions

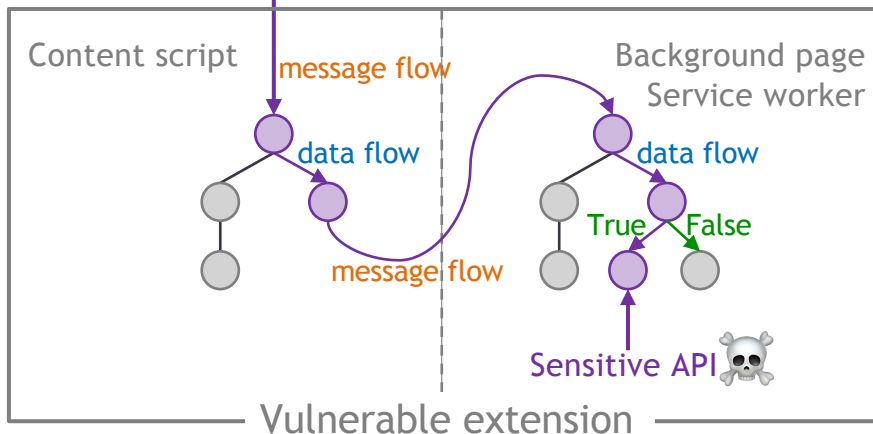


> DOUBLEX: Statically Detecting Vulnerable Data Flows in Browser Extensions

In ACM CCS 2021. Aurore Fass, Dolière Francis Somé, Michael Backes, and Ben Stock



Malicious web page



Per-component JavaScript code abstraction

- AST (Abstract Syntax Tree)
- Control flow
- Data flow
- Pointer analysis

Extension Dependence Graph (EDG)

- Message interactions

Suspicious data flow tracking

- Detects any path between an attacker & sensitive APIs

Simplified Example of a Vulnerability

```
1 // Content script code = from the extension
2 window.addEventListener("message", function(event) {
3
4
5
6 })
```

Simplified Example of a Vulnerability

```
1 // Content script code = from the extension
2 window.addEventListener("message", function(event) {
3
4
5
6 })
```

message received



Simplified Example of a Vulnerability

```
1 // Content script code = from the extension
2 window.addEventListener("message", function(event) {
3     if (1 === 1) {
4         window["e" + "val"](event.data);
5     }
6 })
```

message received



Simplified Example of a Vulnerability

```
1 // Content script code = from the extension
2 window.addEventListener("message", function(event) {
3     if (1 === 1) {
4         window["e" + "val"](event.data);
5     }
6 })
```

message received (arrow pointing to `event`)

eval (bracket under `["e" + "val"]`)



```
// DOUBLEX report 🔭
{"direct-danger1": "eval",
 "value": "eval(event.data)",
 "line": "4 - 4",
 "dataflow": true, ✅
 "param1": {
   "received": "event",
   "line": "2 - 2"}}
```

Simplified Example of a Vulnerability

```
1 // Content script code = from the extension
2 window.addEventListener("message", function(event) {
3     if (1 === 1) {
4         window["e" + "val"](event.data);
5     }
6 })
```

message received (purple arrow pointing to `event`)

Not detected by prior work (blue text) **✗** (red X)

eval (red bracket under `["e" + "val"]`)



```
// DOUBLEX report 🔭
{"direct-danger1": "eval",
 "value": "eval(event.data)",
 "line": "4 - 4",
 "dataflow": true,
 "param1": {
   "received": "event",
   "line": "2 - 2"}} ✓
```

Simplified Example of a Vulnerability

```
1 // Content script code = from the extension
2 window.addEventListener("message", function(event) {
3     if (1 === 1) {
4         window["e" + "val"](event.data);
5         
6
7         
8         event = {"data": 42};
9         eval(event.data);
10    }
11 })
```

Simplified Example of a Vulnerability

```
1 // Content script code = from the extension
2 window.addEventListener("message", function(event) {
3     if (1 === 1) {
4         window["e" + "val"](event.data);
5     }
6     event = {"data": 42};
7     eval(event.data);
8 }
9 })
10
```

Not detected by prior work ✖

False positive for prior work ✖

```
// DOUBLEX report
{"direct-danger1": "eval",
 "value": "eval(event.data)",
 "line": "4 - 4",
 "dataflow": true, ✓
 "param1": {
   "received": "event",
   "line": "2 - 2"
 }},

{"direct-danger2": "eval",
 "value": "eval(42)",
 "line": "8 - 8",
 "dataflow": false} ✓
```

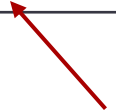
Simplified Example of a Vulnerability

```
1 // Content script code = from the extension
2 window.addEventListener("message", function(event) {
3     if (1 === 1) {
4         window["e" + "val"](event.data);    Not detected by prior work ❌
5     }
6 })
```



```
// Attacker code = from the targeted web page
postMessage("alert(1)", "*")
```

(very) malicious payload



Simplified Example of a Vulnerability

```
1 // Content script code = from the extension
2 window.addEventListener("message", function(event) {
3     if (1 === 1) {
4         window["e" + "val"](event.data);    Not detected by prior work ✗
5     }
6 }
```

eval

developer.chrome.com indique

1

OK

```
// Attacker code = from the targeted web page
postMessage("alert(1)", "*")
```

(very) malicious payload

Detecting Vulnerable Extensions with DOUBLEX

Analyzed 155k Chrome extensions from 2021 with DOUBLEX (takes 2–3s per extension)

- **184 vulnerable Chrome extensions**
- **Impacting 3M users*** (* based on Google's definition)
- **Precision: 89%** of the flagged extensions are vulnerable
- **Recall: 93%** of known vulnerabilities [Somé, S&P 2019] are detected
- **Open source**, for developers and Web users
(even in other fields, e.g., mini apps [Wang et al., ICSE 2023])



[Aurore54F/DoubleX](https://github.com/Aurore54F/DoubleX)

Detecting Fingerprintable Extensions

Browser Extension Fingerprinting

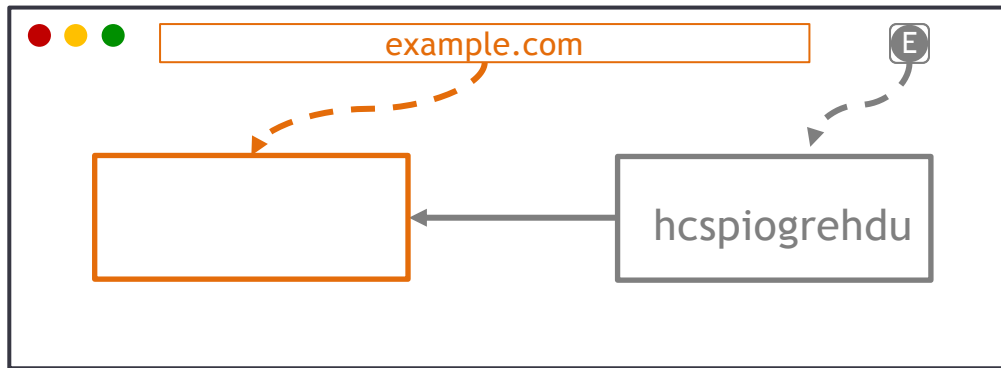
Browser extensions can interact with web pages...

- 1) Extensions send **PostMessage** to web pages

Browser Extension Fingerprinting

Browser extensions can interact with web pages...

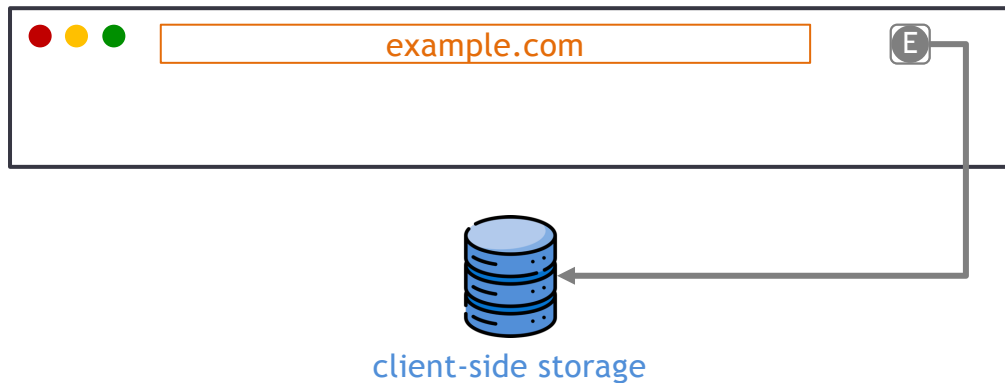
- 1) Extensions send **PostMessage** to web pages



Browser Extension Fingerprinting

Browser extensions can interact with web pages...

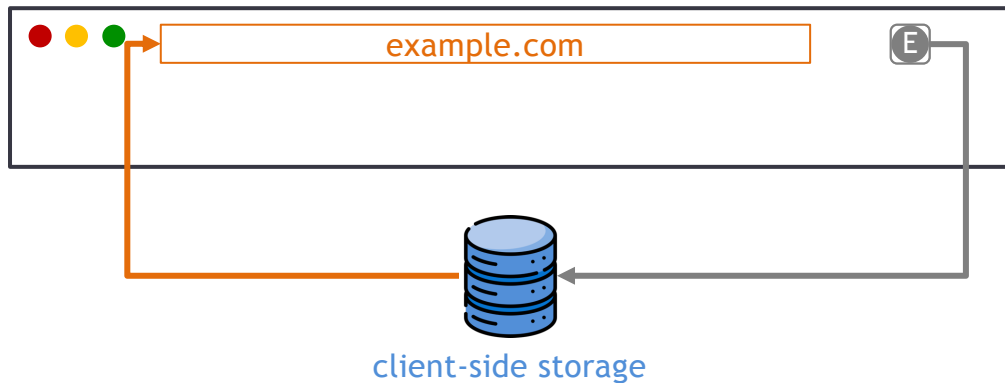
- 1) Extensions send **PostMessage** to web pages
- 2) Extensions store data on the client side through **storage APIs**
(e.g., cookies, local/session storage, IndexedDB)



Browser Extension Fingerprinting

Browser extensions can interact with web pages...

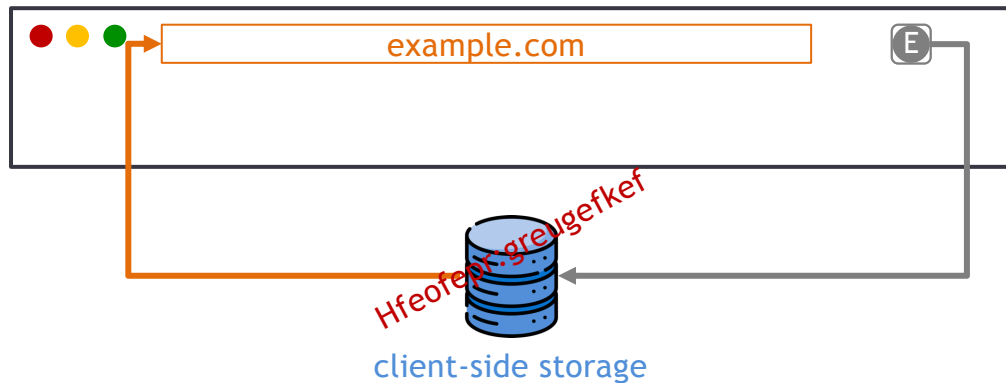
- 1) Extensions send **PostMessage** to web pages
- 2) Extensions store data on the client side through **storage APIs**
(e.g., cookies, local/session storage, IndexedDB)



Browser Extension Fingerprinting

Browser extensions can interact with web pages...

- 1) Extensions send **PostMessage** to web pages
- 2) Extensions store data on the client side through **storage APIs**
(e.g., cookies, local/session storage, IndexedDB)



Browser Extension Fingerprinting

Browser extensions can interact with web pages...

- 1) Extensions send **PostMessage** to web pages
- 2) Extensions store data on the client side through **storage APIs**
(e.g., cookies, local/session storage, IndexedDB)
- 3) Extensions **inject JavaScript** code directly into web pages
 - registering global variables
 - invocation of global APIs and properties

Browser Extension Fingerprinting

Browser extensions can interact with web pages...

- 1) Extensions send **PostMessage** to web pages
- 2) Extensions store data on the client side through **storage APIs**
(e.g., cookies, local/session storage, IndexedDB)
- 3) Extensions **inject JavaScript** code directly into web pages
 - registering global variables
 - invocation of global APIs and properties

... which leaves traces → **observable side effects**, can be seen by a “malicious” site

Browser Extension Fingerprinting

Browser extensions can interact with web pages...

Why is this bad?

- 1) Extensions send PostMessage to web pages
- 2) Extensions store data on the client side through storage APIs (e.g., cookies, local/session storage, indexedDB)
 - “Malicious” websites can track users by fingerprinting their extensions
- Attackers can know if a user has a vulnerable extension installed
- 3) Extensions inject JavaScript code directly into web pages
 - registering global variables
 - invocation of global APIs and properties
 - Extensions can reveal personal user information, e.g., geolocation, ethnicity, social/personal interests, medical issues, religion, etc. [Karami; NDSS'19]

... which leaves traces → observable side effects, can be seen by a “malicious” site

Detecting Fingerprintable Extensions



Agarwal et al.
CCS 2024

> Peeking through the window: Fingerprinting Browser Extensions through Page-Visible Execution Traces and Interactions

In ACM CCS 2024. Shubham Agarwal, Aurore Fass, and Ben Stock



Analyzed 38k Chrome extensions from 2024 with Raider

- **>2,747 fingerprintable Chrome extensions** | impacting **>169M users**
- **Notified 1,967 developers** about their fingerprintable extension(s)
 - Only 30 (!) replied
 - Of those, only 16 positively acknowledged the issues
- Raider PoC is **available online**  <https://github.com/raider-ext/raider>

Detecting Malicious Extensions

In *ACM TWEB* 2026. Ben Rosenzweig, Valentino Dalla Valle, Giovanni Apruzzese, and Aurore Fass

Rosenzweig
et al. TWEB
2026

[illegible]

In *ACM TWEB* 2026. Ben Rosenzweig, Valentino Dalla Valle, Giovanni Apruzzese, and Aurore Fass

7,140
malicious
extensions

Last update 2017–23

63,598
“benign”
extensions

Last update 2012–22

Detecting Malicious Extensions — Lab Setting



Rosenzweig
et al. TWEB
2026



> It's not Easy: Applying Supervised ML to Detect Malicious Extensions in the CWS

In ACM TWEB 2026. Ben Rosenzweig, Valentino Dalla Valle, Giovanni Apruzzese, and Aurore Fass

It's not Easy: Applying Supervised Machine Learning to Detect Malicious Extensions in the Chrome Web Store
Ben ROSENZWEIG, University of Amsterdam, Amsterdam, the Netherlands
Valentino DALLA VALLE, University of Amsterdam, Amsterdam, the Netherlands
Giovanni APRUZZESE, University of Amsterdam, Amsterdam, the Netherlands
Aurore FASS, University of Amsterdam, Amsterdam, the Netherlands

DATASET

7,140
malicious
extensions

Last update 2017–23

63,598
“benign”
extensions

Last update 2012–22



FEATURES

Source code [A]

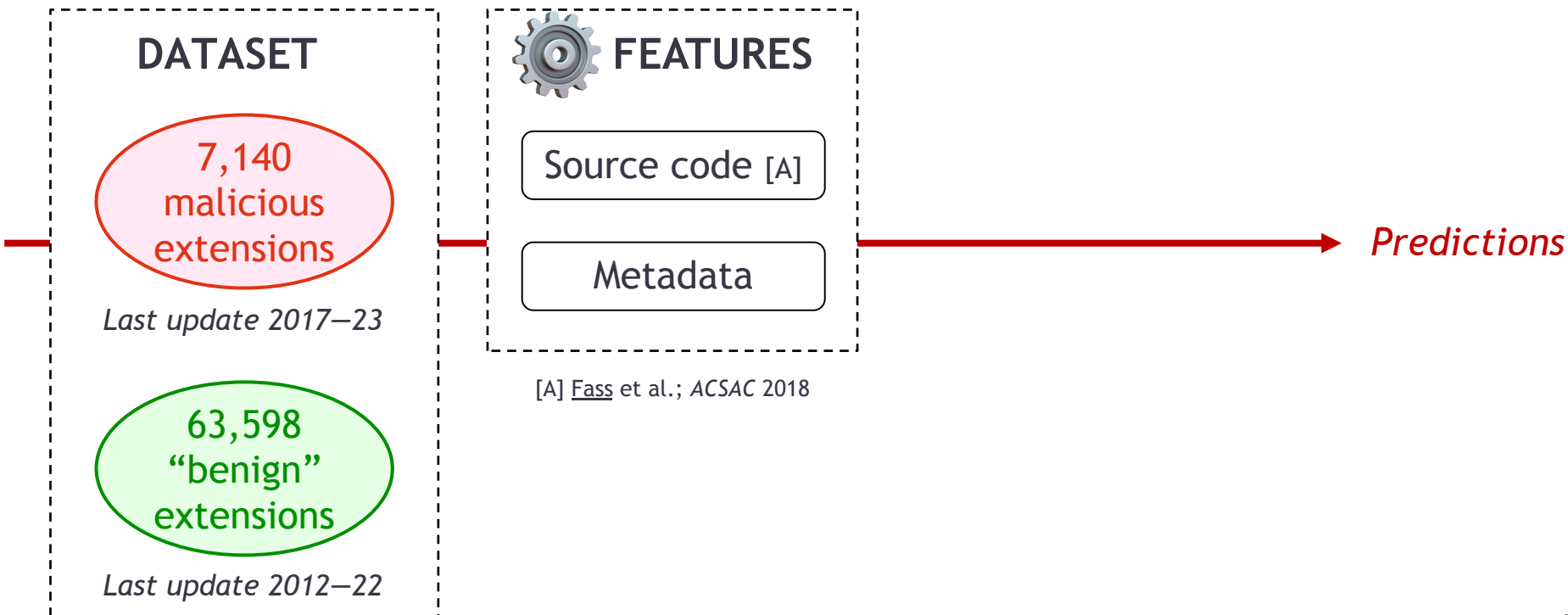
Metadata

[A] Fass et al.; ACSAC 2018

Rosenzweig
et al. TWEB
2026

[illegible]

In *ACM TWEB* 2026. Ben Rosenzweig, Valentino Dalla Valle, Giovanni Apruzzese, and Aurore Fass



Detecting Malicious Extensions – Lab Setting



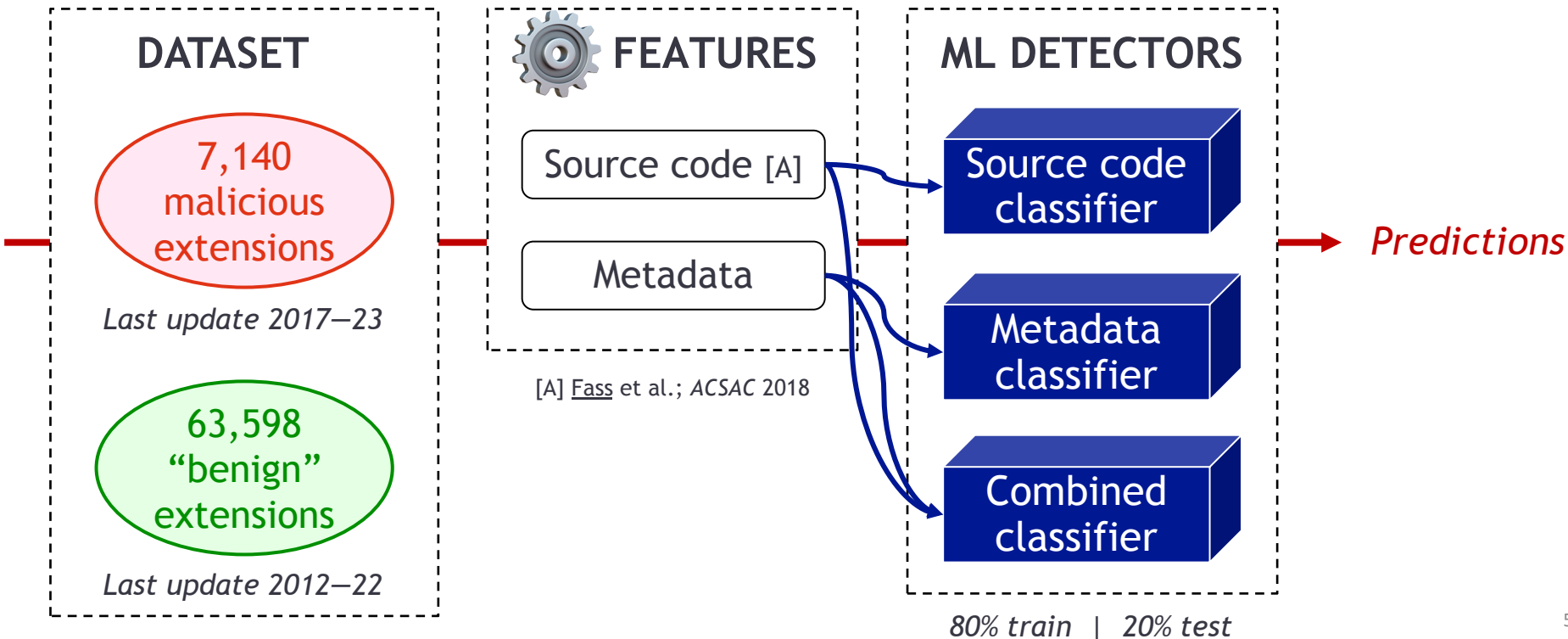
Rosenzweig
et al. TWEB
2026



> It's not Easy: Applying Supervised ML to Detect Malicious Extensions in the CWS

In ACM TWEB 2026. Ben Rosenzweig, Valentino Dalla Valle, Giovanni Apruzzese, and Aurore Fass

It's not Easy: Applying Supervised Machine Learning to Detect Malicious Extensions in the Chrome Web Store
Ben ROSENZWEIG, University of Cambridge, Cambridge, UK
Valentino DALLA VALLE, University of Cambridge, Cambridge, UK
Giovanni APRUZZESE, University of Cambridge, Cambridge, UK
Aurore FASS, University of Cambridge, Cambridge, UK



In *ACM TWEB* 2026. Ben Rosenzweig, Valentino Dalla Valle, Giovanni Apruzzese, and Aurore Fass



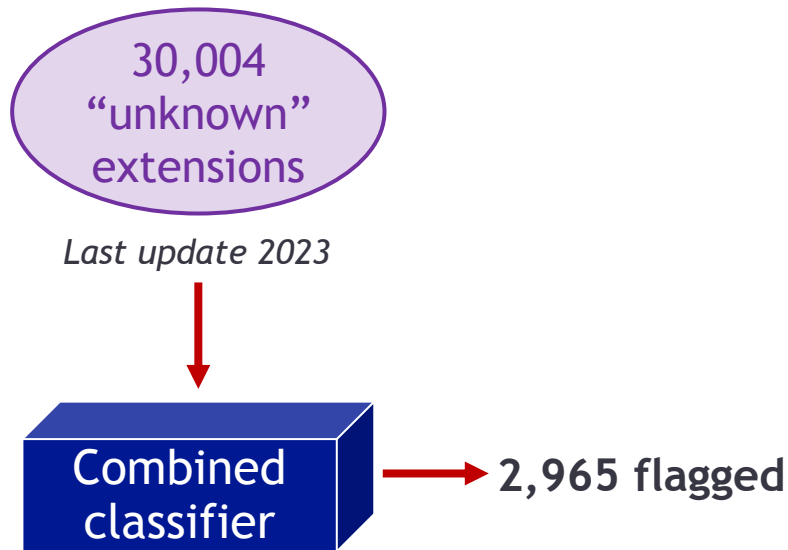
Detecting Malicious Extensions – Real World

30,004
“unknown”
extensions

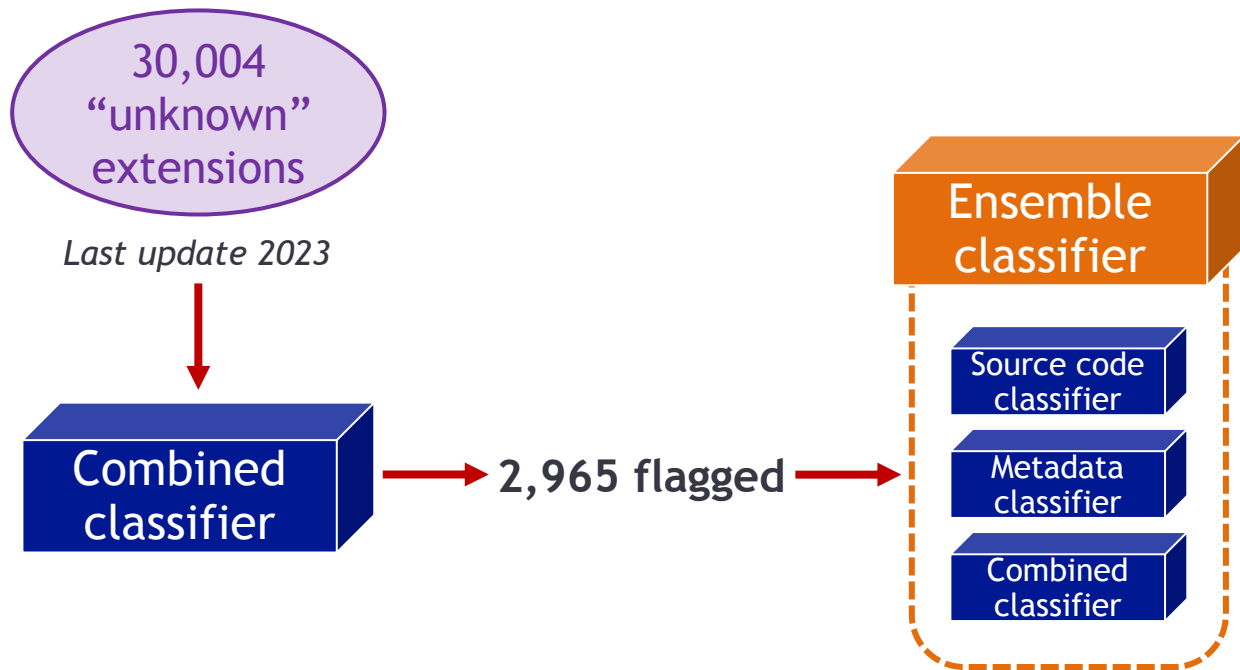
Last update 2023



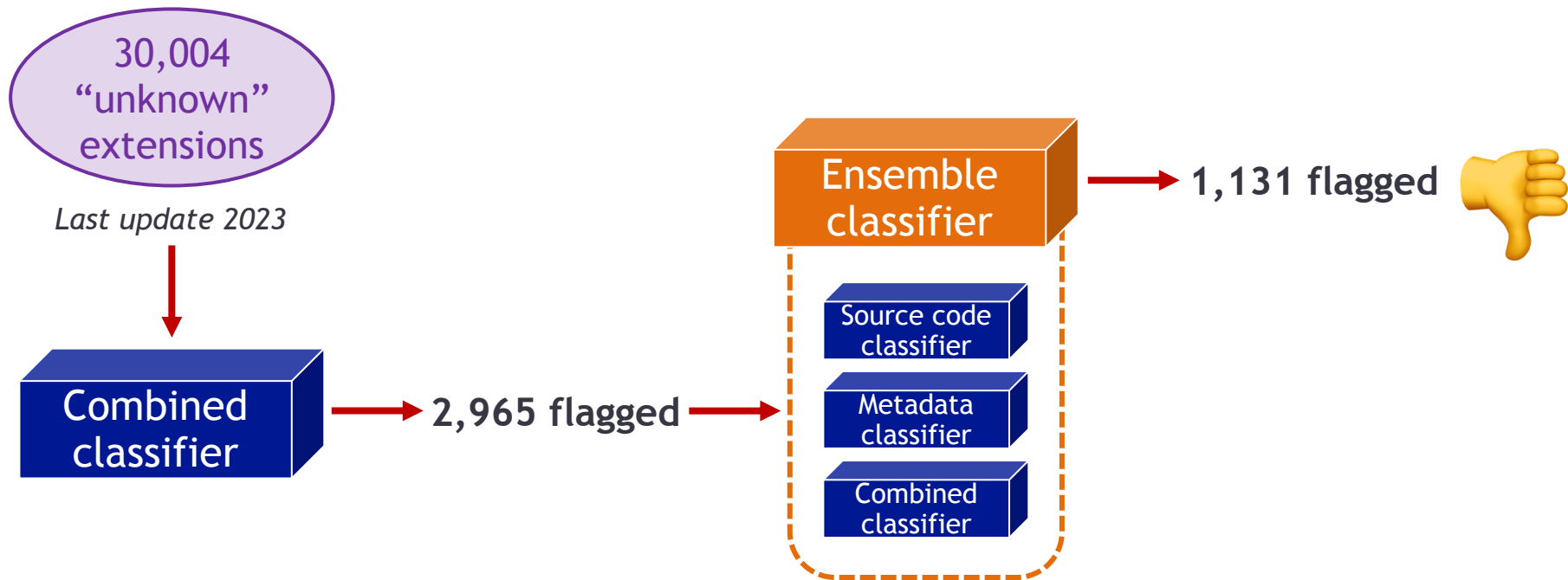
Detecting Malicious Extensions – Real World



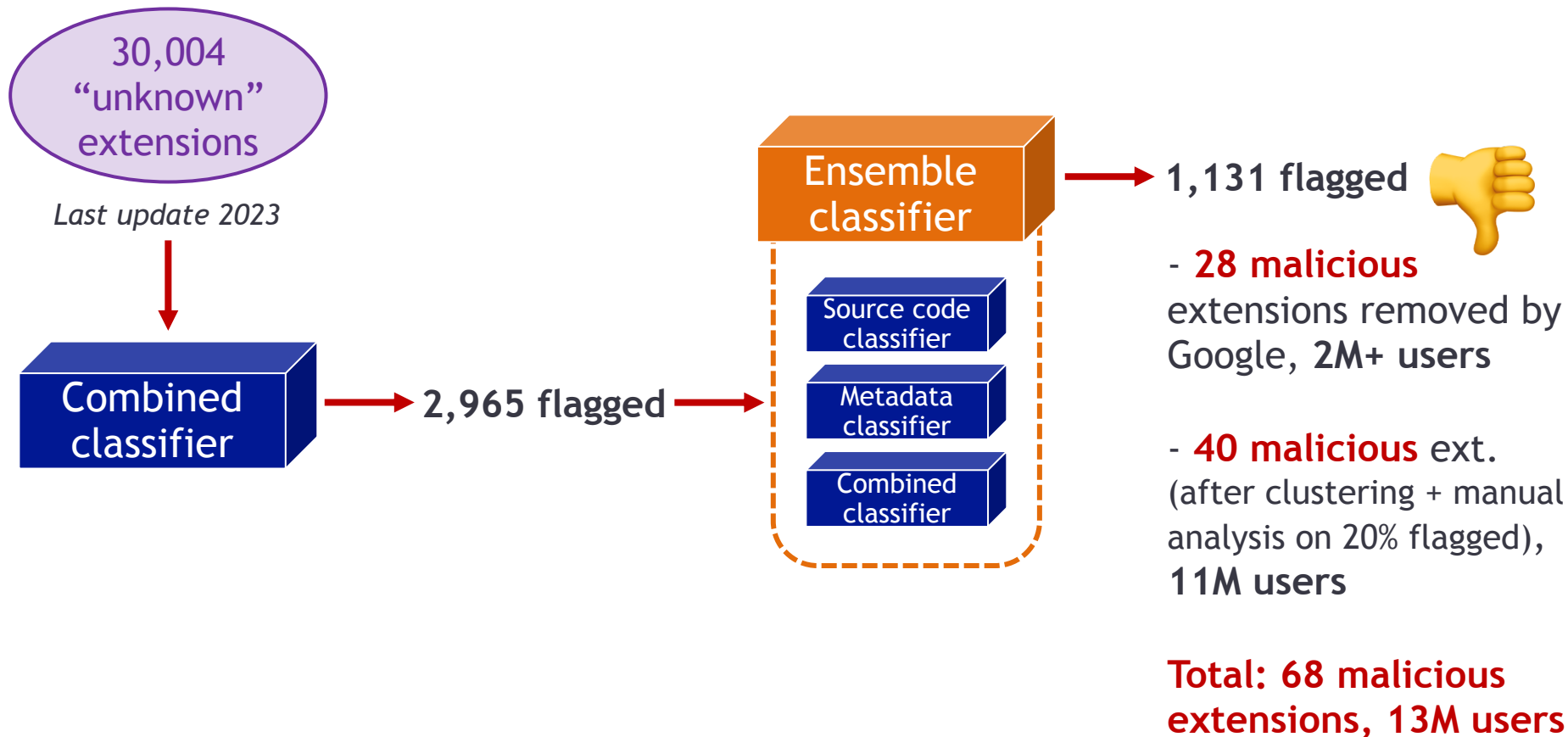
Detecting Malicious Extensions – Real World



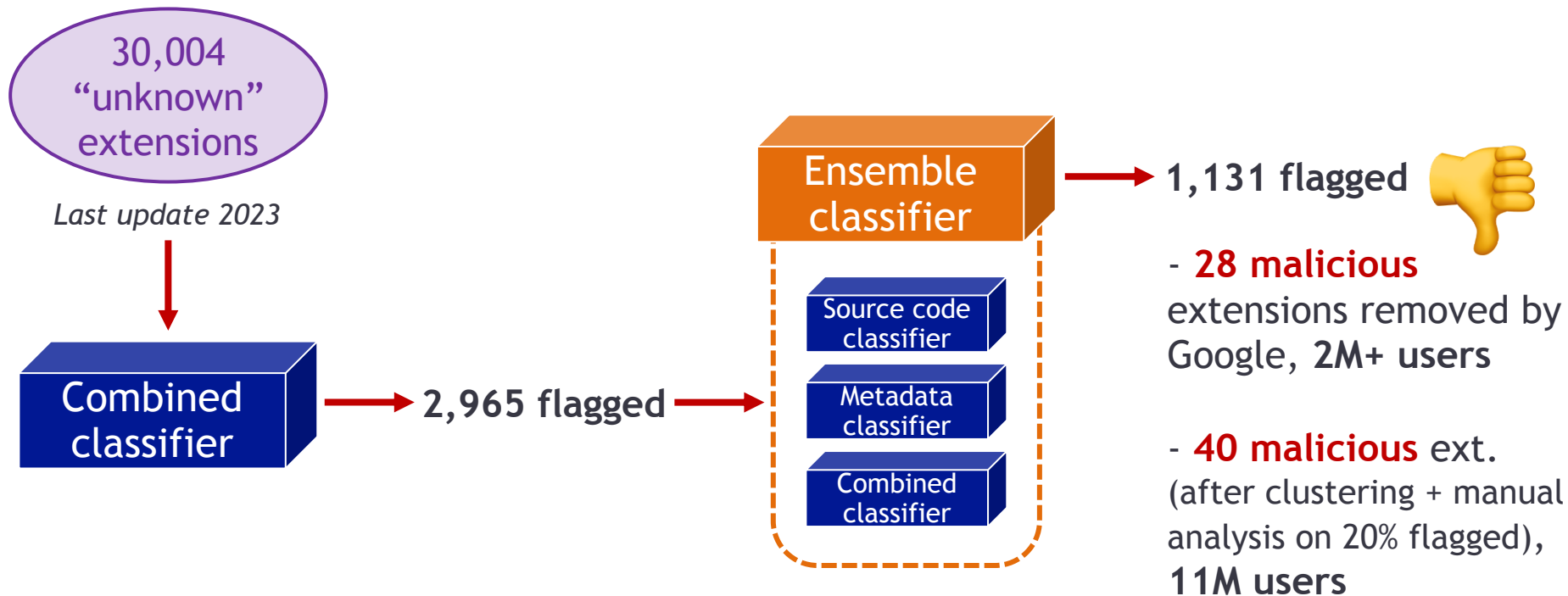
Detecting Malicious Extensions – Real World



Detecting Malicious Extensions – Real World



Detecting Malicious Extensions – Real World



May 2024: disclosure of the 40 extensions to Google, no response

As of Sept. 2025: 17 / 40 malicious extensions were taken down

Total: 68 malicious extensions, 13M users

Detecting Malicious Extensions – Lab Setting vs. Real World

- Lab setting: 98.37% accuracy
- Real world: 1,131 / 30,004 extensions flagged | 68 verified malicious extensions

???

Detecting Malicious Extensions – Lab Setting vs. Real World

- Lab setting: 98.37% accuracy
- Real world: 1,131 / 30,004 extensions flagged | 68 verified malicious extensions

???

- Concept drift
 - Intrinsic evolution of extensions, hard for supervised ML tools to keep a (high) accuracy over time

Detecting Malicious Extensions – Lab Setting vs. Real World

- Lab setting: 98.37% accuracy
- Real world: 1,131 / 30,004 extensions flagged | 68 verified malicious extensions

???

- Concept drift
 - Intrinsic evolution of extensions, hard for supervised ML tools to keep a (high) accuracy over time
- Our code and datasets are publicly available:



<https://github.com/its-not-easy/tweb25/>

Same Extension, Different Stores



Chaudhry et al.
MADWeb 2026

> Two Heads are Better Than One: Analysing Extensions Across Stores

In *MADWeb 2026*. [Abdullah Chaudhry](#), [Valentino Dalla Valle](#), and [Aurore Fass](#)

Two Heads are Better Than One: Analysing Browser Extensions Across Stores

Abdullah Chaudhry
University of Cambridge
a.chaudhry@cam.ac.uk

Valentino Dalla Valle
University of Cambridge
v.dalla.valle@cam.ac.uk

Aurore Fass
University of Cambridge
a.fass@cam.ac.uk

Abstract. Browser extensions are a popular way to extend the functionality of web browsers. However, they are often used to deliver malicious content, and their use is increasing. In this paper, we analyse the distribution of browser extensions across different stores, and compare the results to previous work. We find that the distribution of extensions is highly skewed, with a small number of extensions accounting for a large proportion of the total. We also find that the distribution of extensions is different across different stores, and that the distribution of extensions is changing over time.

1. Introduction
The Web has become the primary global interface for most people, and as a result, the browser has become a critical piece of software. Browser extensions are a popular way to extend the functionality of web browsers, and their use is increasing. In this paper, we analyse the distribution of browser extensions across different stores, and compare the results to previous work. We find that the distribution of extensions is highly skewed, with a small number of extensions accounting for a large proportion of the total. We also find that the distribution of extensions is different across different stores, and that the distribution of extensions is changing over time.



Chaudhry et al.
MADWeb 2026

Abdellah Hassan Chantley CISPA Helmholtz Center for Information Security abdellah.chantley@cispa.de	Valestino Della Valle CISPA Helmholtz Center for Information Security valestino.della-valle@cispa.de	Arnon Fiat Info Centre at University of Aveiro arnon.fiat@ua.pt
--	---	--

In *MADWeb 2026*. Abdullah Chaudhry, Valentino Dalla Valle, and Aurore Fass

- 

Summary

Dangerous Browser Extensions

→ Extensions can put their users' security & privacy at risk:

- Contain **malware**: designed by malicious actors to harm victims
 - E.g., propagate malware, steal users' credentials, track users
- Contain **vulnerabilities**: designed by well-intentioned developers... but buggy
 - E.g., can lead to user-sensitive data exfiltration
- Violate the Chrome Web Store policies
 - E.g., deceive users, promote unlawful activities, lack a privacy policy
- Be **fingerprintable**: can be recognized and uniquely identified
 - E.g., can lead to user tracking or inferring of user personal information

Hsu et al.
AsiaCCS
2024

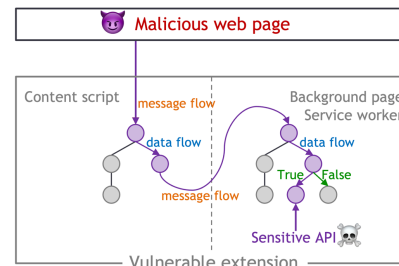
Detecting Fingerprintable Extensions with Raider

- 1) Extensions send **PostMessage** to web pages
- 2) Extensions store data on the client side through **storage APIs**
(e.g., cookies, local/session storage, IndexedDB)
- 3) Extensions **inject JavaScript** code directly into web pages
 - registering global variables
 - invocation of global APIs and properties

Raider-ext/raider

➤ Raider detects 2,747 fingerprintable extensions | 169M users

Detecting Vulnerable Extensions with DOUBLEX



Fass et al.
CCS 2021

Aurore54F/DoubleX

➤ DOUBLEX detects suspicious data flows in browser extensions

184 vulnerable extensions | Precision: 89% | Recall: 93%

Detecting Malicious Extensions – Lab Setting vs. Real World

- Lab setting: 98.37% accuracy
 - Real world: 1,131 / 30,004 extensions flagged | 68 verified malicious extensions
- ???
- Concept drift
 - Intrinsic evolution of extensions, hard for supervised ML tools to keep a (high) accuracy over time



Rosenzweig
et al. TWEB
2026

its-not-easy/tweb25



REDACTED :)



Corresponding Publications

- [What is in the Chrome Web Store?](#)

Sheryl Hsu, Manda Tran, and [Aurore Fass](#). In *ACM AsiaCCS* 2024

- [DoubleX: Statically Detecting Vulnerable Data Flows in Browser Extensions at Scale](#)

[Aurore Fass](#), Dolière Francis Somé, Michael Backes, and Ben Stock. In *ACM CCS* 2021

- [Peeking through the window: Fingerprinting Browser Extensions through Page-Visible Execution Traces and Interactions](#)

Shubham Agarwal, [Aurore Fass](#), and Ben Stock. In *ACM CCS* 2024

- [It's not Easy: Applying Supervised ML to Detect Malicious Extensions in the Chrome Web Store](#)

Ben Rosenzweig, Valentino Dalla Valle, Giovanni Apruzzese, and [Aurore Fass](#). In *ACM TWEB* 2026

- [Two Heads are Better Than One: Analysing Extensions Across Stores](#)

Abdullah Hassan Chaudhry, Valentino Dalla Valle, and [Aurore Fass](#). In *MADWeb* 2026